



Risk Register

TASCO Insurance × VETC Growth Platform — Delivery & Change

iorta TechNXT

Version 1.0 · 07 October 2026

Contents

Heat map (current scores)

Register

Risk review procedure

Document	Version	Date	Owner	Status
Risk Register	1.0	07 October 2026	iorta TechNXT — Delivery Lead	Issued for submission

Scoring: Likelihood (L) 1–5 × Impact (I) 1–5 = Score (S). **Rating:** 1–6 Low · 8–12 Medium · 15–25 High. **Status values:** Open · Mitigating · Mitigated (control delivered, residual risk monitored) · Monitoring · Closed.

The register is reviewed weekly by the Delivery Lead and PO, and the top 10 go to every Steering Committee. Owners are named roles. The party codes are defined in the RACI Matrix (raci.pdf).

Heat map (current scores)

L \ I	1	2	3	4	5
5					
4			R-14	R-06, R-12	R-01
3			R-17, R-21, R-24, R-27	R-04, R-07, R-08, R-09, R-11, R-13, R-15, R-19, R-20, R-25, R-28	R-02, R-05, R-10
2		R-26	R-23, R-30	R-22, R-29	R-03
1			R-18	R-16	

Register

Risks and scores

ID	Risk (cause → event → effect)	Category	L	I	S	Owner
R-01	VETC data access delayed or restricted. The data-sharing legal basis or VETC internal approval is not obtained in time, so no real profile data reaches the platform and scoring and journeys cannot be validated on real behaviour.	Dependency / Data	4	5	20	V-PRD + T-BUS
R-02	Discount/benefit regulation. Customer-facing copy or a benefit is construed as an unlawful discount, rebate or inducement on price-regulated TNDS (Law 08/2022/QH15), leading to regulatory sanction and reputational damage.	Regulatory	3	5	15	T-CMP
R-03	Loyalty points promised before legal approval. Wording such as "confirm expiry in-app (earns points)" implies points while <code>loyalty_points</code> is <code>pending_legal_review</code> , creating a mis-selling or inducement complaint.	Regulatory / Content	2	5	10	T-CMP
R-04	Anti-spam breach. Journey frequency, contact windows or missing consent breach Decree 91/2020/ND-CP, leading to carrier blocking of the brandname, fines and complaints.	Regulatory	3	4	12	T-CMP
R-05	PDP law non-compliance (Decree 13/2023/ND-CP; the PDP Law effective 2026). Personal data is processed without valid consent or purpose, or a DSAR is not honoured in time, leading to fines and suspension of processing.	Regulatory / Privacy	3	5	15	T-CMP (DPO)
R-06	Partner channel conflict. Partners (banks, showrooms, agents) that close most TNDS deals see VETC journeys as poaching their customers, so they withdraw or reduce volume.	Commercial	4	4	16	T-PRD (Partner Manager)
R-07	Low customer trust in calls. Customers assume voice bot or telesales calls are scams, causing low answer and conversion rates, complaints and opt-outs.	Customer / Brand	3	4	12	V-PRD
R-08	Voice ASR accuracy for Vietnamese accents. The ASR misrecognises plates and intents for northern, central and southern accents, noisy cars or code-switching, causing high <code>unverified / plate_mismatch</code> outcomes and customer frustration.	Technology	3	4	12	X-VAI + I-AR
R-09	Integration delays (VETC wallet, SSO, TASCO core issuance). APIs are not ready for SIT, so one-tap purchase cannot be tested end-to-end and the pilot slips.	Dependency	3	4	12	T-IT + V-APP
R-10	Adoption by telesales. Agents keep working from spreadsheets or call lists and ignore the inbox and NBA, so handoffs go stale and conversions are lost.	Change / People	3	5	15	V-CC + T-PRD
R-11	Model / scoring bias. Scoring factors (engagement, wallet balance, region) systematically deprioritise certain groups (for example rural or low-balance customers), leading to unfair treatment and regulatory or ethical concern.	AI governance	3	4	12	T-DAT + T-CMP
R-12	Key person dependency. Knowledge of the rules engine and enrichment logic sits with one or two iorta engineers, so the platform cannot be maintained if they leave.	People / Delivery	4	4	16	I-DL
R-13	Vendor lock-in (voice-AI, messaging, cloud). Proprietary APIs make switching costly or impossible.	Architecture / Commercial	3	4	12	I-AR

ID	Risk (cause → event → effect)	Category	L	I	S	Owner
R-14	Data quality worse than assumed. Expiry is reliable for fewer records than expected (baseline ≈ 1 in 10), so journeys mistime and customers are contacted about the wrong date.	Data	4	3	12	T-DAT
R-15	Wrong-person contact and privacy leak. A phone number in VETC data belongs to someone else (sold car, shared phone), so PII or policy data is disclosed to the wrong person.	Privacy	3	4	12	T-CMP
R-16	Payment without explicit customer authorisation. A telesales or partner flow debits a VETC wallet without the customer confirming in their app, leading to disputes and a breach of the "never pay by phone" promise.	Process / Integration	1	4	4	V-APP + T-PRD
R-17	Zalo ZNS template approval or OA verification delayed. Templates are rejected or slow to approve, so the Zalo channel is unavailable at pilot.	Dependency	3	3	9	V-PRD
R-18	Physical damage sold without the required inspection. MOTOR_PD has <code>requiresInspection: true</code> ; binding without inspection would lead to underwriting losses and fraud.	Underwriting	1	3	3	T-PRD (Underwriting)
R-19	Rule misconfiguration (scoring, journeys, tariffs). A wrong rule is approved, leading to mis-priced quotes or mass mis-targeting.	Operational	3	4	12	T-CMP
R-20	Security breach / account takeover of staff or partner credentials, leading to data exfiltration or fraudulent issuance.	Security	3	4	12	T-SEC
R-21	Telecom/notification provider outage , so reminders and calls fail around expiry dates.	Operational	3	3	9	T-IT
R-22	Performance at full base (≈ 6M vehicles). Recompute or ingestion jobs exceed batch windows, so leads go stale.	Technology	2	4	8	I-AR
R-23	Scope creep (new products and journeys added mid-build), pushing the MVP late.	Delivery	2	3	6	T-PRD
R-24	Tết and holiday disruption. Release or pilot activity coincides with Tết, when customers and staff are unavailable.	Schedule	3	3	9	I-DL
R-25	Customer-app experience below expectation (VETC webview limits, slow load), so renewals fall back to telesales.	UX	3	4	12	I-UX + V-APP
R-26	Accessibility non-conformance , leading to complaints and exclusion of older drivers.	UX / Compliance	2	2	4	I-UX
R-27	Claims expectations not met. FNOL fast-lane promises a 4-hour acknowledgement but the claims team is understaffed, damaging trust at the most important moment.	Operational	3	3	9	T-PRD (Claims Lead)
R-28	Commission miscalculation or caps exceeded , leading to regulatory breach or partner disputes.	Financial / Regulatory	3	4	12	T-PRD (Finance)
R-29	Audit or log integrity failure. Audit records are tampered with or lost, so compliance evidence is unavailable.	Compliance	2	4	8	T-SEC
R-30	Rule cache lag across replicas. An approved rule takes up to 15 s to propagate (<code>CACHE_TTL_MS</code>), giving inconsistent behaviour briefly.	Technology	2	3	6	I-AR

Mitigation, contingency and status

ID	Mitigation (pre - event)	Contingency (if it happens)	Status
R-01	Data - sharing agreement drafted in week 1. Minimum viable field list agreed (plate, phone, toll class, tag date, app activity, consent flags). Synthetic generator keeps the build moving.	Start the pilot on TASCO's own policy book (renewal journey only) with VETC contact through the app only. Escalate to SteerCo.	Open
R-02	Copy guard (<code>copy_guard.json</code>) at rule validation and at send time, normalising spacing and punctuation ("giảm giá", "cash back"). Benefits gated by <code>legalStatus</code> (only approved shown to customers). Pricing copy states "regulated premium, same everywhere". Legal sign-off of every template and the voice script at G3.	Deactivate the offending template or benefit through the Rules studio (new version, approved within the hour). Customer notice if required.	Mitigating
R-03	Delivered: the "earns points" wording was removed from NBA labels and the customer app. <code>loyalty_points</code> stays <code>pending_legal_review</code> and is flagged to staff only. Customer copy never promises points.	Withdraw the wording. Honour any points already promised through a non-cash goodwill gesture approved by Legal.	Mitigated
R-04	<code>contact_policy</code> enforces 08:00–20:00 local time, 1 marketing contact per day, 3 per week, 2 call attempts per week, and consent per channel. Delivered: voice campaigns now pass the same contact policy (KI-09 fixed); a simulated date or time is honoured only in demo mode (KI-33 fixed); touchpoints blocked only by the contact window are deferred, not sent late. Weekly review of message volumes per customer.	Pause journeys (stop the scheduled <code>journeys</code> job). Tighten the policy through the Rules studio. Notify carriers and the regulator if required.	Mitigating
R-05	DPIA in Discovery. Consent centre in the customer app. DSAR export and erasure endpoints. PII field encryption and blind indexes. Purpose-based masking. Retention rule set. Data localisation confirmed. Erasure also scrubs handoffs, claim text and voice signals, and ends the subject's sessions.	DPO incident procedure. Notify the authority within the legal deadline. Suspend the affected processing.	Mitigating
R-06	Partner API with transparent commission. Partner-attributed vehicles are recognised through partner source records. Agreed rules of engagement (for example, suppress conquest for vehicles recently quoted by a partner). Partner council.	Commercial renegotiation. A NBA rule that suppresses VETC journeys for partner-protected vehicles.	Open
R-07	Disclosure at call start. Plate-first verification (the bot never reads the plate). "Never asks for OTP or payment". Payment only in the official app. Calls from the official hotline. In-app notice before or after the call. Trust script on scam concern.	Shift the mix to app/Zalo, reduce call volume, run a public awareness campaign in the VETC app.	Mitigating
R-08	Vendor shortlist with accent benchmarks ($\geq 92\%$ plate-capture accuracy proposed). Up to 3 plate attempts. Keyword NLU covers unaccented variants. Monitor <code>plateVerificationFailureRate</code> in the governance figures (Audit page).	Route failed verifications to telesales or a link. Retune the vendor. Swap the vendor behind the telephony port.	Open
R-09	Contracts frozen at G1. Sandbox adapters with identical ports. Contract tests. Twice-weekly integration sync.	Pilot with signed links plus telesales issuance. Shift the pilot start and hold the Tết freeze.	Open
R-10	Involve agents in usability tests. Champions network. Inbox designed for ≤ 3 clicks to claim and call. Incentives aligned with platform-recorded wins. Supervisor dashboards.	Supervisor reassignment, targeted coaching, retire the legacy lists.	Open

ID	Mitigation (pre-event)	Contingency (if it happens)	Status
R-11	Explainable additive scoring with reasons per factor. No protected attributes used. Quarterly fairness review by province and vehicle category. Simulation before changes.	Adjust weights through the Rules studio. Add a minimum-service rule so every lapsed vehicle gets at least a service notice.	Monitoring
R-12	Pairing. ADRs. KT plan with reverse-shadow. Code walkthroughs. Documentation as part of the DoD. Two people trained per component.	Accelerate KT. Retain an iorta support contract.	Mitigating
R-13	Hexagonal ports and adapters (<code>src/adapters/integrations/*</code> , composition root <code>src/bootstrap/container.js</code>). Standard PostgreSQL. No proprietary cloud services in the core. Exit clauses in contracts.	Replace the adapter. Data export from vendor contracts.	Monitoring
R-14	Confidence-based NBA (<code>fix_data</code> asks for confirmation when confidence < 0.5). <code>verify_expiry</code> steps. Voice bot captures expiry. Data steward workflow. DQ KPIs.	Restrict the pilot to records with confidence ≥ 0.5. Run "confirm your expiry" campaigns first.	Mitigating
R-15	Plate-first verification before any detail. Masked plate in calls. Minimal data in messages. <code>wrong_person</code> outcome creates a DQ issue.	Incident handling, DQ correction, apology.	Mitigating
R-16	Delivered: the staff order endpoint and the <code>policy:issue</code> permission were removed. Staff quote and send the quote to the customer's VETC app (<code>POST /api/quotes/:id/send</code>). Only the customer can pay, in the app. Partner sales are partner-collected (no wallet debit). Production wallet adapter to keep in-app confirmation.	Refund through compensation. Reconcile. Retrain agents.	Mitigated
R-17	Submit templates in Sprint 2. Templates written within ZNS rules (transactional tone). Channel fallback order in journeys.	Use app push and SMS only.	Open
R-18	Delivered: payment is blocked on every channel until a passed inspection is recorded on the quote (<code>POST /api/quotes/:id/inspection</code>). The customer app explains that an assessor will contact the customer.	Hold <code>MOTOR_PD</code> issuance on digital channels by removing <code>vetc_app</code> from its channels (rule change).	Mitigated
R-19	Validation, simulation and four-eyes approval. Description required. Monitoring after activation. Tariffs approved by Underwriting. Restricted kinds need a compliance officer approver. Activation is transactional, with one active version per kind enforced in the database.	Rollback (new draft from the prior version, fast-tracked approval). Customer remediation.	Mitigating
R-20	MFA for admin, approver, compliance and steward roles, self-enrolled by the user, with code replay protection (extend to all roles in production through the IdP). Lockout after 5 failures across password and code. Short JWT TTL (30 min); password and role changes revoke tokens. Rate limits. API keys hashed, shown once and scoped. Audit hash chain. Pen test.	Revoke tokens and keys, disable users (<code>PATCH /api/users/:id</code>), reset MFA (<code>POST /api/users/:id/reset</code>), incident response, forensics from the audit log.	Mitigating
R-21	Circuit breakers per gateway. Ops status page. Journeys retry the next channel. Catch-up window (<code>catchUpDays</code>).	Manual re-run of journeys for missed dates. Switch provider.	Monitoring
R-22	Incremental rebuild by plate. Paging (1,000 per page); journey runs page through all due touchpoints. Postgres indexes. Perf tests. Horizontal scaling.	Run jobs off-peak. Partition by province.	Monitoring
R-23	Rules-first design: many requests are configuration, not code. Change control at SteerCo.	Move to Wave 3.	Monitoring
R-24	Change freeze 1–14 February 2027. Soft launch before, full volume after.	Re-plan the pilot.	Mitigating

ID	Mitigation (pre-event)	Contingency (if it happens)	Status
R-25	Performance budgets, usability tests, ≤ 3 taps, skeleton loading, offline-tolerant retry with idempotent orders.	Fix-forward weekly releases. Zalo mini-app fallback.	Open
R-26	WCAG 2.2 AA in the DoD, automated and manual checks.	Remediation sprint.	Monitoring
R-27	SLA visible in the claims queue (sLaDueAt). Staffing plan. Alerts.	Overflow to the TASCO claims hotline. Adjust the published SLA.	Open
R-28	Statutory caps in <code>commission.json</code> enforced by the validator and again at calculation (<code>Math.min(rate, cap)</code>). Monthly statements. Reconciliation. <code>commission</code> changes need a compliance officer approver.	Adjust and re-issue statements. Claw back.	Mitigating
R-29	Append-only hash chain with <code>GET /api/audit/verify</code> . Truncation of <code>audit_log</code> blocked in the database (migration 002). Retention of 10 years. Backups.	Restore from backup. Forensic investigation.	Monitoring
R-30	Event <code>rules.activated</code> invalidates the cache. The short TTL is documented.	None needed beyond awareness. Avoid approving during a peak-send window.	Closed (accepted)

Risk review procedure

1. New risks can be raised by anyone through the delivery tracker using the template above.
2. The Delivery Lead triages within 2 business days, assigning an owner and an initial score.
3. Any risk scoring **High (≥ 15)** is escalated to the next Steering Committee with a mitigation plan.
4. A risk is closed only when its owner and the Delivery Lead agree that the cause no longer exists or the residual risk has been accepted by the accountable party in the RACI.